

Identity Governance & JIT Access

Entra ID, Privileged Identity Management, and just-in-time privileged access architecture

Overview

Identity governance minimizes standing privileged access by combining Microsoft Entra ID's directory and Conditional Access engine with Privileged Identity Management (PIM) for time-bound role elevation — the foundation of a defensible just-in-time (JIT) access model for both cloud admin and application-level privileges.

Entra ID Foundations

	Details
Tenant	Dedicated, isolated directory instance — top-level identity boundary
Conditional Access	Policy engine evaluating signals (user, device, location, risk) to grant/block/require MFA
P1 vs P2 licensing	P1: Conditional Access, group-based access; P2 adds PIM, Identity Protection, access reviews
Break-glass accounts	Cloud-only, excluded from Conditional Access, monitored, credentials sealed/offline
Identity Protection	Risk-based sign-in/user risk scoring feeding Conditional Access risk policies
Access Reviews	Periodic, owner-driven recertification of role/group membership

PIM — Just-In-Time Privileged Access

- **Eligible vs. Active assignment** — eligible roles require activation; active roles are standing (avoid for admin roles)
- **Activation controls** — require MFA, justification, ticket number, and/or approver sign-off before elevation
- **Time-bound activation** — role auto-expires after a defined window (e.g., 1–8 hours), forcing re-activation for continued use

- **PIM for Groups** — extends JIT activation to group membership, cascading to any resource the group is assigned to
- **Alerts** — PIM flags roles activated too frequently, assigned outside PIM, or with stale permissions
- **Access Reviews for PIM roles** — periodic recertification of who holds eligible assignments

JIT Architecture Pattern (Cloud-Agnostic)

Request (user submits justification, often via ticket/portal) → **Approval workflow** (automated for low-risk, human approver for high-risk roles) → **Time-bound grant** (PIM activation or a short-lived IAM role/credential, e.g. via a Lambda/Function-based approval automation) → **Automatic revocation** at expiry → **Full audit trail** of request, approval, and usage for compliance evidence.

AWS/Cross-Cloud JIT Equivalents

- **AWS IAM Identity Center + permission sets** — time-limited session duration on assumed roles
- **STS AssumeRole** with short session tokens — foundation for custom JIT approval automation (e.g., Lambda-triggered)
- **Just-in-time EC2 access** — Systems Manager Session Manager removes standing SSH/RDP exposure entirely
- **GCP** — Privileged Access Manager (PAM) provides analogous time-bound, approval-gated role grants

Governance Best Practices

- Default to **zero standing access** for privileged roles — everything eligible, nothing permanently active
- Separate **break-glass** accounts from PIM entirely — they must work even if PIM/Conditional Access is misconfigured
- Enforce **MFA + Conditional Access** as a prerequisite for any PIM activation, not just initial sign-in
- Route all activations through **centralized logging** (Entra sign-in/audit logs → Sentinel) for anomaly detection
- Pair PIM with **access reviews** on a recurring cadence to catch role sprawl and unused eligibility

Common Pitfalls

	Fix
Privileged roles assigned as Active by default	Default every privileged role to Eligible; require PIM activation for use
No approval required for sensitive role activation	Require approver and justification for Global Admin-tier and similar high-impact roles
Break-glass accounts subject to Conditional Access	Explicitly exclude break-glass accounts from CA policies; monitor for any sign-in
PIM activation with no time limit tuning	Set the shortest practical activation window per role sensitivity
Access reviews configured but never actioned	Assign accountable reviewers and track completion; auto-remove on non-response

Interview / Exam Quick Hits

- PIM requires **Entra ID P2** licensing — P1 alone does not include just-in-time role activation
- **Eligible assignments** show zero standing privilege in access reviews until explicitly activated
- Break-glass accounts should be **excluded** from Conditional Access to guarantee emergency access if policy misfires
- PIM activation approval can be **multi-stage** — different approvers for different sensitivity tiers of role
- Combine PIM with **Conditional Access authentication context** to require step-up auth only at the moment of privileged action